

API SECURITY RISK ANALYSIS

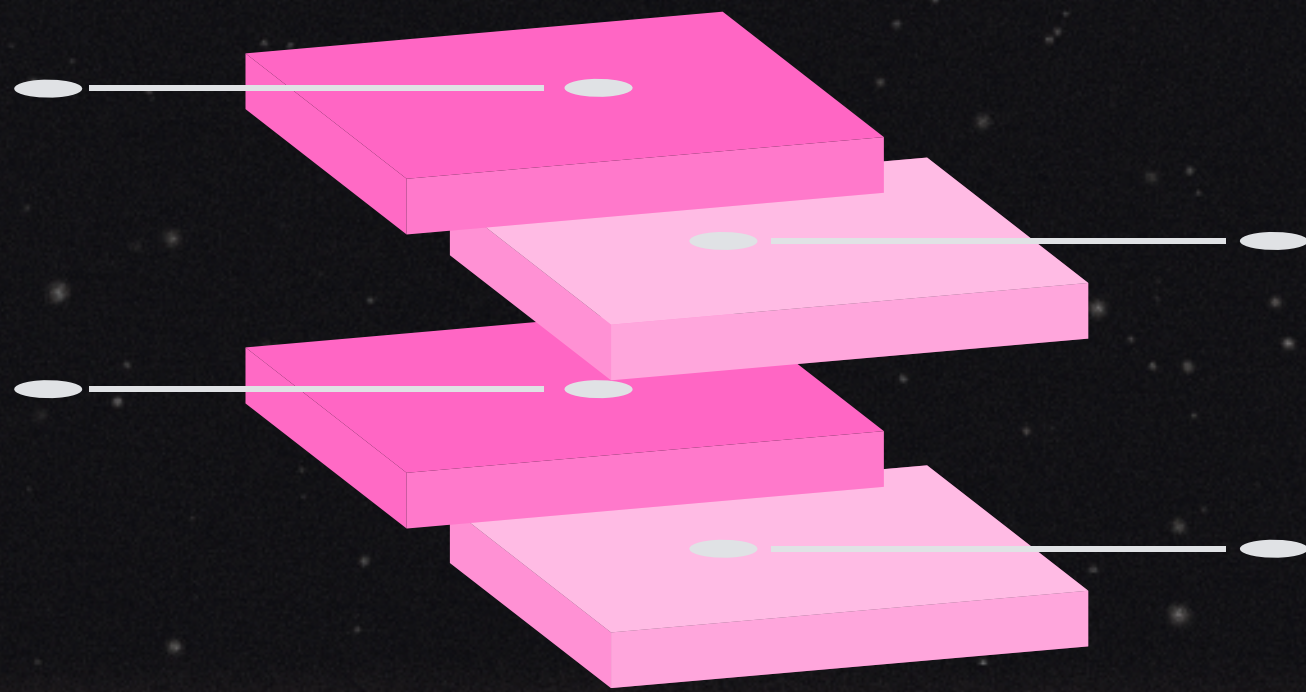
Target: JSONPlaceholder
(jsonplaceholder.typicode.com)

Munnuru Akshitha

EXECUTIVE SUMMARY

This report analyzes the JSONPlaceholder public test API using Postman to identify common API security risks. Testing revealed 4 findings, ranging from Low to High risk, including broken authorization, excessive personal data exposure, missing rate limiting, and weak input validation. This assessment follows the OWASP API Security Top 10 framework and reflects the type of read-only security review performed by AppSec consultants for SaaS platforms.

CYBER SECURITY RISKS



Authorization & Data Exposure

Broken Authorization (High Risk): Any user's data (e.g., todos) is accessible by simply changing the ID number in the URL — no ownership verification exists.

Excessive Data Exposure (High Risk): The /users endpoint returns full personal details — name, email, phone, and exact GPS coordinates — without any authentication required.

Rate Limiting & Validation

Missing Rate Limiting (Medium Risk): Repeated rapid requests are never blocked, throttled, or flagged — enabling potential scraping or abuse.

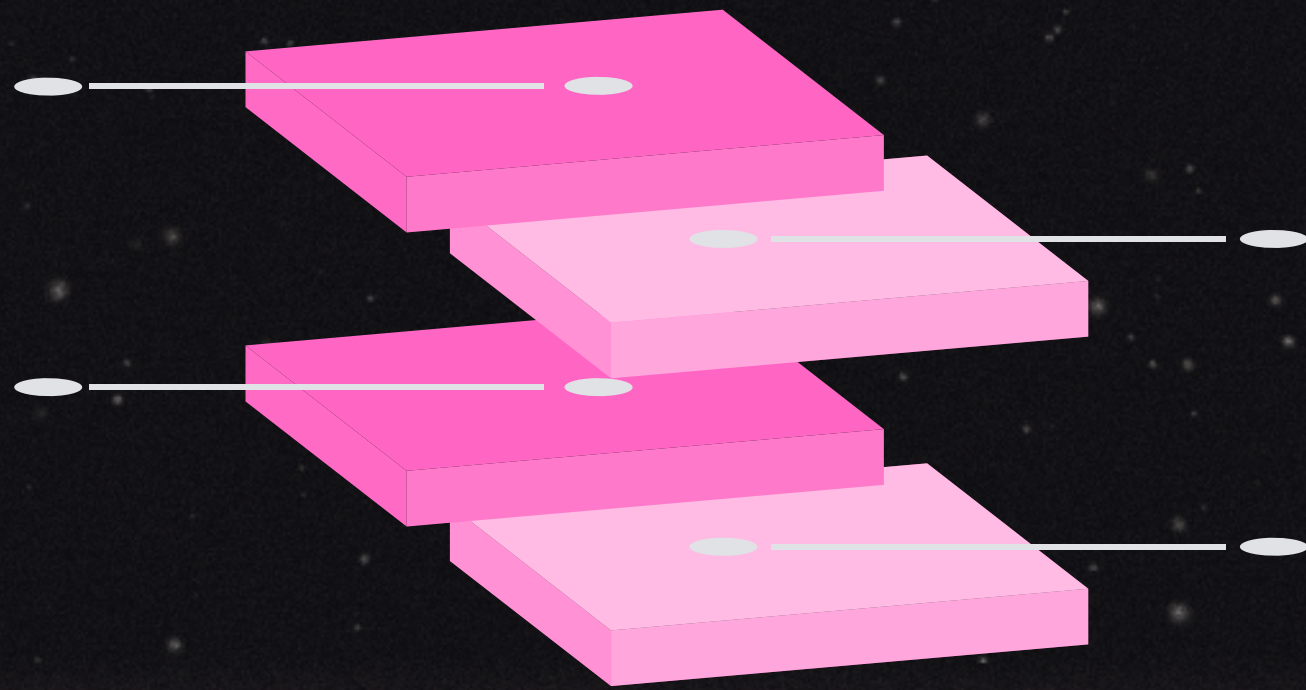
Poor Input Validation (Low Risk): Invalid or malformed IDs return empty responses instead of clear, descriptive error messages.

BUSINESS IMPACT

Business Impact: Could expose any user's private data (orders, messages, personal records) and enable stalking or targeted phishing through leaked location and contact details.

Business Impact: Enables large-scale data scraping or denial-of-service attacks, and may indicate weaker backend validation that could be exploited further.

REMEDIATION & CONCLUSION



Priority fixes:

1. Implement authorization checks on every request (verify resource ownership)
2. Limit API responses to only necessary fields; require authentication for personal data
3. Add rate limiting per IP/API key
4. Return clear, standardized error messages for invalid input

This assessment shows that even simple, well-documented APIs can carry serious risks when authorization and data controls aren't properly enforced. Addressing broken authorization should be the top priority.

THANK YOU